

BÁO CÁO LAB 9

ĐÁNH GIÁ AN TOÀN THÔNG TIN CHO ỨNG DỤNG WEB

Họ tên: UNG VẴNG ĐẠI LÂM MSSV: 2380601202 Lớp: 23DATA1

Hình thức: Cá nhân. Mã nguồn: github.com/UngVangDaiLam/ATw-CSDL_Lab (thư mục lab9).

⚠ **Đạo đức:** Chỉ kiểm thử trên ứng dụng mục tiêu tự dựng (localhost:9090), môi trường được phép. Không đánh giá hệ thống của người khác khi chưa có sự cho phép.

1. Phạm vi và phương pháp

Mục tiêu đánh giá: ứng dụng web "TargetApp" (Node.js + SQLite) chạy tại `http://localhost:9090`, gồm các chức năng: đăng nhập (`/login`), tìm kiếm (`/search`), trang admin (`/admin`) và API hồ sơ (`/api/profile`).

Công cụ: trình duyệt + proxy bắt gói (Burp Suite Community / OWASP ZAP) để quan sát request-response, kết hợp kiểm thử thủ công và một script Python (`assessment/assess.py`) tự động hoá các phép thử.

Phương pháp: theo hướng OWASP — thu thập thông tin (liệt kê form, tham số URL, header, cookie), rồi thử các lỗ hổng phổ biến: Injection, XSS, Broken Authentication/Session, Broken Access Control.

2. Tổng hợp lỗ hổng phát hiện

Phát hiện **6 lỗ hổng** (4 mức CAO, 2 mức TRUNG BÌNH):

#	Lỗ hổng	Mức độ	Vị trí	OWASP
1	SQL Injection	CAO	POST /login	A03 Injection
2	Reflected XSS	CAO	GET /search?q=	A03 Injection
3	Broken Auth / Session	CAO	Cookie auth	A07 Auth Failures
4	Broken Access Control	CAO	GET /admin	A01 Access Control
5	IDOR	TRUNG BÌNH	GET /api/profile?id=	A01 Access Control
6	Cookie thiếu cờ bảo mật	TRUNG BÌNH	Set-Cookie	A05 Misconfig

```
$ python assess.py
[DÍNH] CAO SQL Injection (A03)
Payload "' OR '1'='1' --" đăng nhập được mà không cần mật khẩu.

[DÍNH] CAO Reflected XSS (A03)
Tham số 'q' được phản chiếu nguyên văn, chưa mã hoá -> script thực thi.

[DÍNH] CAO Broken Auth / Session (A07)
Cookie 'auth' không ký, chỉ cần đặt auth=hacker:admin là chiếm quyền admin.

[DÍNH] CAO Broken Access Control (A01)
Trang /admin lộ danh sách toàn bộ user (kể cả email) mà không xác thực thật.

[DÍNH] TRUNG BÌNH IDOR (A01)
/api/profile?id= không kiểm tra quyền -> đọc hồ sơ bất kỳ: id=1:user1/user, id=2:alice/user, id=3:admin/admin

[DÍNH] TRUNG BÌNH Cookie thiếu cờ bảo mật (A05)
Set-Cookie: thiếu HttpOnly, thiếu Secure, thiếu SameSite -> JS đọc được cookie, dễ bị đánh cắp.

=====
TỔNG: phát hiện 6 lỗ hổng.
```

Hình 1. Kết quả chạy script đánh giá tự động

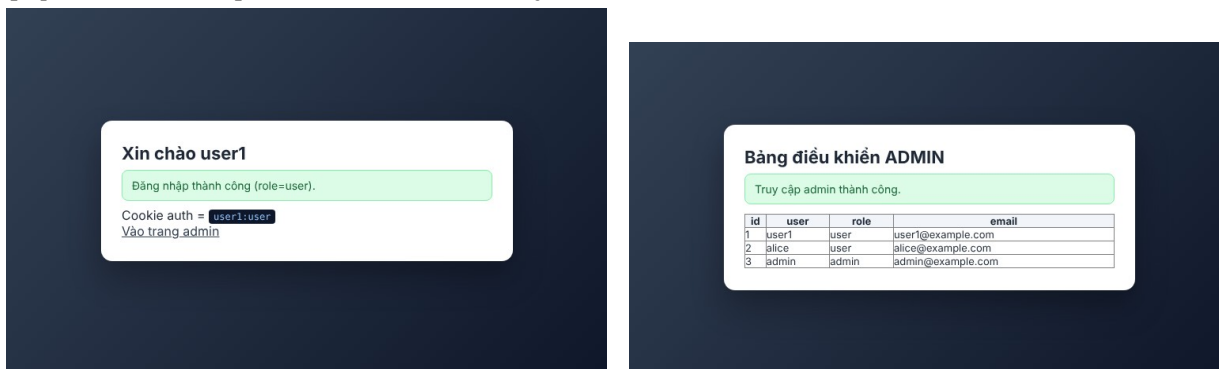
3. Chi tiết, bằng chứng và đề xuất khắc phục

[1] SQL Injection (CAO). Câu truy vấn nối chuỗi trực tiếp. Payload `` OR '1'='1' --` ở ô Username đăng nhập được mà không cần mật khẩu (Hình 2). *Khắc phục:* dùng **prepared statement/ORM**, kiểm tra đầu vào, tối thiểu quyền tài khoản DB.

[2] Reflected XSS (CAO). Tham số `q` được in ra HTML không mã hoá; `` thực thi trong trình duyệt. *Khắc phục:* **mã hoá đầu ra** theo ngữ cảnh, thêm **CSP**, lọc bằng DOMPurify nếu cho HTML.

[3] Broken Authentication/Session (CAO). Vai trò lưu trong cookie `auth=user:role` không ký, không HttpOnly; chỉ cần đặt `auth=hacker:admin` là thành admin. *Khắc phục:* dùng **session ID ngẫu nhiên lưu ở server**, không để client quyết định vai trò.

- [4] **Broken Access Control (CAO)**. `/admin` chỉ xét cookie giả mạo được, cho xem **toàn bộ user kèm email** (Hình 3).
 Khắc phục: kiểm tra xác thực & phân quyền thật ở server cho mọi request nhạy cảm.
- [5] **IDOR (TRUNG BÌNH)**. `/api/profile?id=` không kiểm tra chủ sở hữu → đổi `id` đọc hồ sơ bất kỳ. *Khắc phục:* kiểm tra tài nguyên thuộc về người đang đăng nhập; dùng định danh khó đoán.
- [6] **Cookie thiếu cờ bảo mật (TRUNG BÌNH)**. Set-Cookie thiếu **HttpOnly, Secure, SameSite** → JS đọc được, dễ bị đánh cắp qua XSS. *Khắc phục:* bật đủ 3 cờ và chạy HTTPS.



Hình 2 & 3. Trái: SQLi đăng nhập không cần mật khẩu. Phải: truy cập trang admin bằng cookie giả mạo, lộ dữ liệu user.

Hình 4. Bản đồ các lỗ hổng theo vị trí, mức độ và cách khắc phục

4. Đánh giá chung và khuyến nghị

- Ứng dụng mắc đủ các nhóm lỗ hổng phổ biến nhất của OWASP Top 10 (A01, A03, A05, A07) — rủi ro tổng thể **cao**: kẻ tấn công có thể chiếm quyền admin và lấy toàn bộ dữ liệu người dùng.
- Ưu tiên xử lý ngay** các lỗ mức CAO: tham số hoá truy vấn, mã hoá đầu ra, thay cơ chế session, thêm kiểm soát truy cập phía server.
- Bổ sung lớp phòng thủ: HTTPS + security headers (helmet/CSP/HSTS), rate limit & khoá tài khoản, ghi log và giám sát, kiểm thử bảo mật định kỳ (SAST/DAST, OWASP ZAP).

5. Kết luận

Quy trình đánh giá theo hướng OWASP đã phát hiện 6 lỗ hổng trên ứng dụng mục tiêu, trong đó 4 ở mức cao cho phép chiếm quyền và rò rỉ dữ liệu. Mỗi lỗ hổng đều có biện pháp khắc phục rõ ràng; áp dụng đầy đủ (như đã minh hoạ ở Lab 8) sẽ đưa ứng dụng về trạng thái an toàn. Đánh giá bảo mật cần được thực hiện định kỳ và tích hợp vào quy trình phát triển.